

Penetration Test Report

Pentest Blackbox

Prepared for Kemangconfi Dental care

Document version	1.109
Report date	2026-05-04
Classification	CONFIDENTIAL
Methodology	PTES, OWASP WSTG v4.2, OWASP API Top 10 (2023), NIST SP 800-115
Engagement window	2026-05-03 to 2026-05-04
Authoring firm	SentinelScan Greybox Team

1. Document Control & Revision History

This report is the property of Kemangconfi Dental care and is classified as CONFIDENTIAL. Distribution is restricted to authorized recipients identified in the rules of engagement. Any redistribution requires prior written approval.

Revision history

Version	Date	Author	Notes
1.109	2026-05-04	SentinelScan	Initial release

2. Executive Summary

SentinelScan executed a greybox penetration test against Kemangconfi Dental care's in-scope assets. Across 0 confirmed findings, we identified 0 critical, 0 high, 0 medium, and 0 low severity issues. The most material risks relate to general security hygiene.

The risk posture chart below summarizes the distribution of confirmed findings by severity band. Critical and High items must be remediated within the timelines defined by the customer's vulnerability management policy (typically 7 and 30 days respectively).



Key recommendations

No remediations required at this time.

3. Scope & Rules of Engagement

Engagement	Pentest Blackbox
Client	Kemangconfi Dental care
Classification	CONFIDENTIAL
Web targets	https://www.kemangconfidentalcare.com
API base URL	(none)

Rules of engagement

Greybox engagement. No destructive payloads, no DoS testing. Scanner identifies as `User-Agent: SentinelScan/1.0`. Findings reported within 24h of confirmation.

4. Methodology

Testing followed a hybrid greybox approach combining authenticated active scanning, passive analysis of provided artefacts (source code, OpenAPI specifications, infrastructure-as-code), and manual exploitation of high-impact findings. Coverage maps to the following authoritative methodologies:

- PTES (Penetration Testing Execution Standard) — phases: pre-engagement, intelligence gathering, threat modeling, vulnerability analysis, exploitation, post-exploitation (identification only), reporting.
- OWASP Web Security Testing Guide v4.2 — 100+ test cases across information gathering, configuration, authentication, session management, authorization, input validation, error handling, cryptography, business logic, client-side and API testing.
- OWASP API Security Top 10 (2023) — BOLA, broken authentication, BFLA, mass assignment, security misconfiguration, etc.
- OWASP ASVS L1–L3 — verification controls applied selectively to in-scope components.
- NIST SP 800-115 — technical assessment guide for planning, executing and reporting.
- CIS Benchmarks — for cloud and infrastructure baseline comparison.
- MITRE ATT&CK — each finding is mapped to a relevant adversary technique where applicable.

5. Risk Rating Methodology (CVSS v3.1)

Findings are scored using the Common Vulnerability Scoring System v3.1 base metric group. Each finding lists a CVSS vector composed of attack vector (AV), attack complexity (AC), privileges required (PR), user interaction (UI), scope (S), and the confidentiality (C) / integrity (I) / availability (A) impact metrics. Severity bands follow the FIRST mapping:

Severity	CVSS Range	Customer SLA
Critical	9.0 – 10.0	Patch within 7 days
High	7.0 – 8.9	Patch within 30 days
Medium	4.0 – 6.9	Patch within 60 days
Low	0.1 – 3.9	Patch in next quarterly cycle
None	0.0	Informational

6. Summary of Findings

No findings were identified during this engagement.

6.1 Severity × Asset Heatmap

The heatmap visualises how confirmed findings cluster across in-scope assets. Cells are coloured by severity band; the number indicates the count of findings of that severity on that asset. Use this view to prioritise asset-level remediation campaigns.

No findings to plot.

6.2 Retest Delta vs Previous Report

Comparison vs the previous report (0 findings).

Bucket	Count	Notes
Resolved since last report	0	Findings present previously, no longer reproducible.
Persisting	0	Findings still present in the current scan.
Newly introduced	0	Findings not seen in the previous report.

Newly introduced findings

None.

Resolved findings

None.

8. Remediation Roadmap

The roadmap below sequences remediation work by risk × effort. Items at the top should be addressed first.

No remediation actions required.

9. Appendix A — Tools & Methodology

The following tools and engines were orchestrated by the SentinelScan platform during this engagement. The platform normalizes output from each engine into a common finding schema so that severities and remediations are consistent regardless of the producing tool.

- OWASP ZAP / Nuclei templates — web active scanning (XSS, SQLi, SSRF, IDOR).
- sslyze-style TLS probing — protocol, cipher and certificate hygiene.
- Nmap — service / version discovery for in-scope hosts.
- Trivy / Checkov — IaC and cloud configuration analysis.
- Semgrep — source-level SAST with curated ruleset.
- OSV / Trivy — software composition analysis on declared dependencies.
- Internal hybrid orchestrator — header / CORS / OpenAPI fuzzing and rate-limit probes.

9. Appendix B — Glossary

BOLA	Broken Object Level Authorization — a server fails to verify the caller is allowed to access the requested object identifier.
BFLA	Broken Function Level Authorization — a server fails to enforce role / function restrictions on an endpoint.
CSP	Content Security Policy — a browser-enforced policy restricting which sources may serve scripts, styles and other resources.
CVE	Common Vulnerabilities and Exposures — public catalogue of known vulnerabilities.
CVSS	Common Vulnerability Scoring System — vendor-neutral severity rating system.
CWE	Common Weakness Enumeration — catalogue of software weakness types.
HSTS	HTTP Strict Transport Security — header that forces browsers to use HTTPS.
MITRE ATT&CK	Knowledge base of adversary tactics and techniques mapped to real-world incidents.
PoC	Proof of Concept — minimal artefact demonstrating a vulnerability.
SAST	Static Application Security Testing — source-level analysis.
SCA	Software Composition Analysis — detection of vulnerable third-party packages.
SSRF	Server-Side Request Forgery — server can be coerced to make HTTP requests on the attacker's behalf.